

DAY 26 ASSIGNMENT

CRYPTOGRAPHIC FAILURES

Name:- Rishabh Raj

1. What is cryptography?

Cryptography is the use of mathematical techniques and algorithms to protect information. It helps provide confidentiality, integrity, authentication, and, in some cases, non-repudiation.

2. What is A04:2025 Cryptographic Failures?

A04:2025 Cryptographic Failures is an OWASP Top 10 category describing security problems caused by missing or incorrectly implemented cryptography. Examples include transmitting sensitive data without proper protection, weak or obsolete algorithms, poor key management, and improper storage of sensitive information.

3. What is sensitive data? Give four examples.

Sensitive data is information that could cause harm, privacy loss, fraud, or unauthorized access if exposed. Four examples are passwords, bank or payment information, personal identification information, and authentication/API tokens.

4. Explain data at rest.

Data at rest is information stored on a device or storage system rather than being actively transmitted. Examples include files on a hard drive, database records, backups, and cloud storage. Sensitive data at rest should be protected with appropriate access controls and encryption where required.

5. Explain data in transit.

Data in transit is information moving between systems, such as between a browser and a web server or between two APIs. Sensitive data in transit should be protected using secure protocols such as HTTPS/TLS to reduce interception and tampering risks.

6. What is encryption?

Encryption converts readable plaintext into ciphertext using an encryption algorithm and a key. The ciphertext can be converted back into readable data by an authorized party using the appropriate key.

7. What is hashing?

Hashing is a one-way cryptographic operation that converts input data into a fixed-length digest. A secure hash is designed so that it is computationally difficult to recover the original input from the digest. Passwords should use dedicated password-hashing functions rather than ordinary fast hashes.

8. Explain the difference between encryption and hashing.

Encryption is designed to be reversible when the correct key is available, so it is useful for protecting data that must later be read. Hashing is intended to be one-way and is useful for integrity checks and password verification. Hashing does not provide a normal decryption operation.

9. Why is Base64 not encryption?

Base64 is an encoding scheme used to represent binary data as text. It does not provide confidentiality and requires no secret key. Anyone can decode Base64 data, so it must not be used as a replacement for encryption.

10. Why should passwords never be stored in plaintext?

Plaintext passwords can be immediately exposed if a database or backup is compromised. Passwords should instead be stored using a strong password-hashing algorithm such as Argon2id, scrypt, or bcrypt, with an appropriate unique salt.

11. What is password hashing?

Password hashing is the process of converting a password into a password-derived hash using a password-specific hashing function. During login, the entered password is processed again and compared with the stored result rather than storing the original password.

12. What is a salt?

A salt is a unique random value added to a password before password hashing. The salt is normally stored alongside the password hash. It makes identical passwords produce different stored hashes and helps defend against precomputed password-cracking tables.

13. Why are unique salts useful?

Unique salts ensure that the same password does not result in the same stored hash for different users. They also make large precomputed attacks such as rainbow-table attacks much less useful.

14. What is a cryptographic key?

A cryptographic key is a value used by a cryptographic algorithm to encrypt, decrypt, sign, verify, or otherwise protect data. Keys must be generated securely and protected from unauthorized access.

15. What is key management?

Key management is the secure lifecycle management of cryptographic keys. It includes key generation, storage, distribution, access control, rotation, backup where appropriate, revocation, and secure destruction.

16. Why is hardcoding a production encryption key in source code risky?

Hardcoded keys can be exposed through source repositories, backups, logs, application packages, or developer access. If an attacker obtains the key, protected data may be decrypted or forged. Production keys should be stored and managed through an appropriate secret or key-management system.

17. Explain symmetric encryption.

Symmetric encryption uses the same secret key, or closely related secret material, for encryption and decryption. It is efficient for protecting large amounts of data. AES-GCM is a common modern authenticated-encryption choice when correctly implemented.

18. Explain asymmetric cryptography.

Asymmetric cryptography uses a key pair: a public key and a private key. The public key can be shared, while the private key must be protected. It is commonly used for digital signatures, authentication, certificates, and establishing secure communication keys.

19. What is TLS?

TLS, or Transport Layer Security, is a cryptographic protocol used to protect data exchanged over a network. It provides encryption and integrity and helps authenticate a server through certificates. HTTPS uses HTTP over TLS.

20. Why is HTTPS important when transmitting sensitive information?

HTTPS protects sensitive information while it travels between a client and a server by using TLS. It helps prevent network attackers from reading or modifying credentials, personal information, session data, and other sensitive traffic. Proper certificate validation and secure TLS configuration are also important.